

Hardware CWE SIG Meeting Notes

Meeting Minutes

April 17, 2026

Meeting Attendance

Sohrab Aftabjahani	Alexander Harner	Ashrafi Gulam Mohammed
Irena Bojanova	Bob Heinemann	Bruce Monroe
Steve Christey	Hareesh Khattri	Mitchell Poplingher
Matthew Coles	Mark Labbato	Jason Oberg
Amitabh Das	Mohan Lal	James Pangburn
Keerthi Devraj	Rafael Machado	Mo Rostami
Thomas Ford	Rachana Maitra	Abraham Fernandez Rubio
Jason Fung	Parbati Manna	

Agenda

- RTL WG Update
- Commonly Confused CWEs

Meeting Notes

Bob Heinemann opened the meeting and reviewed the agenda, noting that the target for the CWE 4.20 release is the end of April. Bob reminded attendees that the content development repository is public and can be used to review submissions that are in process. He also noted that new submissions, corrections, and additions to existing content can be submitted through the public submission form.

RTL WG Updates

Bob provided an update on the RTL Working Group, which met twice in March and will meet again on Monday. The group has made progress in summarizing and reframing concerns

1

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CWE Team to ensure accuracy and completeness.

from a CWE perspective. The current focus areas include simulation synthesis mismatches, bad coding practices, and RTL hardware mismatches.

Recently, the MITRE team presented a minimal draft weakness for simulation synthesis mismatches at the last working group meeting. The plan is to use the next RTL session as a working meeting to further develop that draft. The group views simulation synthesis mismatches as part of a chaining relationship, where the mismatch is a resultant weakness caused by primary weaknesses such as RTL coding practices.

In response to a question from Jason about how the group distinguishes a simulation synthesis mismatch from an RTL hardware mismatch, Bob explained that a simulation synthesis mismatch occurs when behavior observed in simulation differs from the behavior produced by synthesis. He also noted that an RTL hardware mismatch refers to cases where the hardware still behaves differently from what was verified, even when there is no simulation synthesis mismatch, with propagation delay and timing effects offered as examples.

When Rachana Maitra asked whether an RTL to gate level mismatch changes logic behavior or instead creates timing-related security exposure, Bob shared that the group appears to be pointing mainly to issues in the physical domain, including timing, but noted that he would confirm details from the working group notes. In response to a question from Sohrab asking whether the discussion was referring to logic synthesis or physical synthesis, Bob added that he did not want to answer without checking and would follow up.

Sohrab Aftabjahani emphasized that many of the examples raised by the working group are already treated as standard functional design issues and should be fixed regardless of security impact. He said silicon bugs that remain uncorrected can create security problems, but they are still functional bugs first. He cited several examples: timing violations, incomplete sensitivity lists, and combinational loops, which are ordinarily addressed through established design and verification activities such as logic mapping checks, static timing analysis, timing closure, and post-manufacture testing. Sohrab added that if the flow from RTL to gate level is performed correctly, logic behavior should remain the same, and that systematic defects should be found and corrected through process and test improvements. While security may raise the priority of some issues, it does not exempt them from normal quality expectations.

Of particular note, one of the key concerns raised in the RTL Working Group is that semantic differences between simulation and synthesis can create verification blind spots. In those cases, verification may be performed against simulated behavior, while the manufactured silicon behaves differently. Bob recommended that the group identify concrete examples and invited Sohrab to attend the next meeting to share his perspective.

Steve Christey observed that the discussion itself showed the need for greater specificity in how the group defines and describes weaknesses, citing the need for clearer language and more precise distinctions so that important details can be captured directly in CWE. He noted that this will need to be refined over the course of the RTL Working Group's work.

Commonly Confused HW CWEs

Jason Oberg delivered a presentation on hardware CWEs that are often confused because of similarity or overlap, sharing observations that stemmed from ongoing industry engagements and detailed review of hardware CWE entries, including work associated with Mark Labbato and partner organizations. The goal of the effort was to identify where CWE entries could be made clearer by providing structure and clarity to areas of overlap so that users can better distinguish related weaknesses and apply them more consistently.

In their review, the team found cases where the same root cause or verification evidence appeared applicable across multiple CWEs, which created confusion about where one CWE ends and another begins. Jason recommended setting a standard of using CWE relationship fields more deliberately to clarify hierarchy and relatedness.

Jason also highlighted some of the most prevalent CWEs in the analysis, noting confusion among CWE-1220, CWE-1262, CWE-1299, and CWE-1222. He described these as related access control weaknesses with differing scope and granularity. He suggested that some of the related entries might be clarified by making them children of CWE-1220, noting that CWE-1222 is already related that way.

Hareesh Khattri and Abraham Fernandez Rubio cautioned that CWE-1220 should not automatically be treated as the top level access control entry for this group because it is specifically about insufficient granularity of access control, not access control broadly. Hareesh noted that other weaknesses, such as differing access paths or incomplete lock coverage, can also lead to improper access control without being granularity issues. Sohrab also noted that not every interface necessarily requires the same access control treatment, since some interfaces may legitimately be privileged.

Steve explained that the overlap arises because some CWEs are organized around the type of mistake, while others are organized around the protected resource, interface, or other dimensions. He said this multi-dimensional structure makes overlap difficult to avoid and is one of the broader organizational challenges in CWE. Jason agreed that a ChildOf relationship may not always be correct, but said some clearer grouping or cross-reference is still needed so the entries do not appear isolated.

Jason also discussed the relationship between CWE-1303 and CWE-1421. He said both deal with shared microarchitectural state, but CWE-1421 is specific to transient execution, while CWE-1303 more generally addresses non-transparent sharing of microarchitectural resources across security contexts.

Jason said his team had considered whether CWE-1303 should be replaced, but later work suggested it should remain because shared resource issues also arise outside transient execution scenarios, including hardware sharing across virtualized environments and interconnect-level designs. He suggested that the two entries should at least be explicitly related.

Steve noted that such relationship updates and explanatory relationship notes should be straightforward to implement. He also cautioned that when related entries are made more visible to users, the group should still aim for clarity so that the same problem does not get mapped inconsistently to multiple CWEs.

Jason pointed out that CWE-1420 through CWE-1423 can be confusing to readers who do not know the intended hierarchy. Steve clarified that CWE-1420 is a parent generalization of CWE-1421, CWE-1422, and CWE-1423, rather than an overlap in the usual sense. He added that hierarchical organization has not historically been developed as extensively in hardware CWE as in some other areas.

Steve also said that some of the overlaps now being identified likely date back to the early stages of hardware CWE development, when many entries were being created quickly and systematic editorial review for overlap was less mature. He said the program is now more stable and more systematic, and this work is helping address issues from that earlier period.

Jason highlighted overlap among CWE-1272, CWE-1258, and CWE-1239. He said that although the titles differ, all three ultimately concern the need to clear sensitive data. He observed that CWE-1258, in particular, reads as very similar in substance to CWE-1272

when the body text is examined, even if the title is phrased differently. He also described CWE-1239 as a more resource-specific zeroization weakness related to registers.

Jason suggested that these entries may need clearer hierarchy or cross-references so users can distinguish general zeroization problems from more specific cases. He also reviewed CWE-1240, CWE-1431, and CWE-325, noting that these entries can be confusing because intermediate state leakage and other weaknesses may arise from implementation choices that users could also interpret as risky cryptographic implementation. He suggested that additional relationships among these entries may help users understand when one entry is a parent, peer, or closely related case of another.

Bob noted that the term implementation may be doing different work across the entries and said any distinction should be clarified if it is intended to be meaningful. Steve added that some CWE areas are inconsistent in how specifically they describe sensitive information, and that this may also contribute to confusion in cryptographic cases.

Jason said the team scoped just under 60 CWEs for one IP and had reviewed only the first 16 so far. He said the confusing or overlapping cases presented in this meeting came from that initial subset, which suggests the issue may be broader, although the full review is not yet complete.

The group agreed that the presentation was useful because it reflected real experience applying hardware CWE content. Bob said he would post the recording and slides, solicit comments on the recommendations from the mailing list, and begin discussing next steps with Steve. Jason also suggested that tagging may be worth exploring as a complement to strict hierarchical views, since different users may need to group related issues in different ways.

The next meeting will be May 15th.

Action Items

- Invite Sohrab to the upcoming RTL Working Group meeting and share the location of past minutes and recordings. (Bob)
- Follow up with Jason on the distinction between simulation synthesis mismatches and RTL hardware mismatches, and include Rachana in the response. (Bob)

- Send a note to the mailing list after the recording and slides are posted to request comments on Jason's recommendations for clarifying related hardware CWE entries. (Bob)
- Discuss internally how to address the identified CWE relationship gaps and possible implementation options. (Bob and Steve)